

Future Work & Research Directions

A source-graded 2026 state-of-the-art scan, a prioritised roadmap, and a concrete next-build plan (P12)

U E Sai Pavan Vamshi Krishna (G25AIT2149) · as of 5 August 2026

Prepared with a rigorous, auditable research method: ~18 sources opened and graded, load-bearing claims traced to primary sources (arXiv, OWASP, NSA), disconfirming queries run, and confidence stated per finding. Vendor/SEO blog figures are labelled and never cited as fact.

1 · Executive summary

Vyuha is **well-positioned, not behind**. Its selective cascade, non-overlapping-guard ensemble, continuous red-team, and honest black-box posture match what independent 2026 sources recommend: *defense-in-depth plus continuous red-teaming and monitoring, aiming at risk reduction rather than elimination*. The question is not whether to rebuild, but where to extend.

The highest-value directions, ranked by decision-weight, are: **(1) go agentic** - extend L3 from *tool-output* scanning to **MCP tool-poisoning and stateful action/capability control**; **(2) add multi-turn / session-level detection**; **(3) run a rigorous adaptive-attack and standardised-benchmark evaluation** (the honest weak point, and the most paper-worthy move); **(4) upgrade the guard ensemble** with one non-overlapping guard. Sections 3 and 5 make these concrete.

Honest correction. Our going-in prior over-weighted “provable guarantees.” The evidence **demoted** that: no certified defense currently stops adaptive attacks, so provable guardrails are a research aspiration, not a near-term deliverable.

2 · How the field moved in 2026

Five shifts, each corroborated by primary or institutional sources, define what a modern defense must now address:

Shift in 2026	What it means	Source
Content → agentic action	Guardrails built for LLMs-as-models miss attacks that unfold over tool-call action sequences; OWASP shipped a new Top 10 for Agentic Applications (ASI01-ASI10).	OWASP Agentic Top 10 2026 SECONDARY
The session , not the prompt	Multi-turn (Crescendo) attacks escalate from benign to harmful across turns at 65-99% success; single-message moderation does not catch them.	Crescendo, USENIX Sec 2025 PRIMARY
No certified defense yet	Adaptive attackers bypass 12 recent defenses at >90% ASR by tuning general optimisers - robustness must be measured, not assumed.	"The Attacker Moves Second" PRIMARY
MCP is the new attack surface	Tool poisoning hides instructions in tool descriptions/metadata (not outputs); NSA, OWASP and multiple papers now treat it as a first-class threat.	MCP-38 taxonomy; NSA MCP guidance PRIMARY
Guard-model reality check	On a 14-model, 79,331-sample NIST-RMF benchmark: recall is the critical metric, model size does NOT predict safety performance, and ensembling non-overlapping guards is recommended.	Guard benchmark, arXiv 2605.28830 PRIMARY

Why this validates Vyuha. The same benchmark found **Qwen Guard (4B) had the highest recall (83.97%)** while larger Llama Guard 12B / GPT-OSS-Safeguard 20B were conservative, missing up to 75% of unsafe content. Your choice of Qwen3Guard, your recall-at-fixed-FPR metric, and your cascade+ensemble design are all endorsed by 2026 evidence.

3 · Prioritised roadmap

Ranked by decision-weight for *this* project (working, free-compute, black-box, single-author). Priority 1 items are green-barred; research stretches are amber-barred.

Direction	What to add to Vyuha	Effort	Free compute?	Evidence
1. Agentic: MCP tool-poisoning + stateful action control	Scan MCP tool descriptions (not just outputs); action-sequence tool policy; instruction hierarchy system>user>tool	Medium	Yes	PRIMARY
2. Multi-turn / session-level detection	Score the whole conversation graph; extend the L5 drift monitor to per-session escalation (catch Crescendo)	Low-Med	Yes	PRIMARY
3. Adaptive-attack + benchmark evaluation	Run Vyuha vs adaptive attacks; report on the NIST-RMF guard benchmark + full AgentDojo	Medium	Mostly	PRIMARY
4. Guard-ensemble upgrade	Add one non-overlapping guard (e.g. Granite Guardian for injection); ensemble + report	Low	Yes (GPU)	SECONDARY
5. Representation-level defense (circuit breakers / RepE)	Reroute harmful internal representations - attack-agnostic, no guard model	High	No (white-box)	PRIMARY
6. Multimodal coverage	Image/audio jailbreak + injection screening	High	Partly	SECONDARY
7. Provable / verifiable-policy guardrails	Formal action-policy verification (ShieldAgent-style)	Very high	No	SECONDARY

The four Priority-1 moves, in detail

1. Go agentic (the top pick - scoped as P12 in Section 5). Your L3 scans tool *outputs*; the 2026 frontier is attacks that never appear in outputs. **MCP tool poisoning** hides instructions in tool *descriptions/metadata* so the agent is compromised before a tool runs (MCP-38 taxonomy; Trust No Tool; NSA guidance). **CASCADE** (arXiv 2604.17125) is literally a cascaded hybrid defense for MCP prompt injection - your architecture, applied to MCP. Extending `InjectionScanner` to tool descriptions and moving `ToolPolicy` toward verifiable action-sequence policy (ShieldAgent / AGrail / CaMeL direction) is timely and paper-worthy. *Confidence: high*.

2. Defend the session, not the prompt. Vyuha is single-turn; Crescendo defeats single-message moderation. Add a lightweight **per-conversation escalation detector** - you already own a drift monitor (PSI); extend it to score the conversation graph over turns. *Confidence: high*.

3. Measure robustness honestly. Your own limitations section is validated by the field: no certified defense stops adaptive attacks. The decision-grade move is to **measure** - run Vyuha against the adaptive attacks of “The Attacker Moves Second,” report on the standardised NIST-RMF guard benchmark, and scale your P11 AgentDojo run past n=2.

This turns an honest weakness into the paper's strongest, most credible contribution. *Confidence: high.*

4. Add one non-overlapping guard. 2026 guidance: pair two guards with complementary strengths and ensemble - which your L1+L2 cascade already does. Granite Guardian (IBM) reportedly leads on prompt-injection; GuardReasoner-Omni adds reasoning/multimodal; X-Guard adds multilingual. Add one, report the ensemble on the benchmark. *Confidence: medium-high (the "Granite leads on injection" claim is from a secondary overview - verify against IBM's primary card).*

4 · Contested, unknown, and what would change the ranking

Contested / unknown

- **Vendor effectiveness figures are unverified.** Numbers like PromptArmor “<1% FPR,” AgentWatcher “near-zero ASR,” and a “340% attack surge” came from SEO/vendor blogs (low reliability) and are **not** cited as fact here.
- **Black-box vs white-box is genuinely contested.** Representation methods report near-zero ASR but require model access; black-box layered defenses report higher residual ASR but deploy anywhere. Vyuha sits firmly and defensibly on the black-box side - a deliberate design choice, not an oversight.

What would flip the ranking

- If the project can use a **model you fine-tune/control**, representation-level defense (circuit breakers) jumps to #1 - it has the strongest measured robustness.
- If your professor steers toward **theory**, the provable/verifiable-policy line becomes the thesis, not a footnote.
- If a **new adaptive attack** specifically defeats cascaded/ensemble guards, the adaptive-evaluation move (3) becomes urgent rather than merely valuable.

5 · P12 build plan - MCP tool-poisoning + stateful-agent extension

The scoped top pick. It extends the agent layer (L3) and the ops layer (L5) to cover the two biggest 2026 gaps - MCP tool poisoning and multi-turn/action-sequence attacks - while staying inside Vyuha's free-compute, black-box, reproducible thesis. It maps directly onto the **OWASP Top 10 for Agentic Applications 2026** (ASIO2 Tool Misuse, ASIO6 Memory/Context Poisoning) and the **MCP-38** taxonomy.

Component A — MCP tool-description scanner (new)

Today L3 scans tool *outputs*. Tool poisoning lives in tool *descriptions/metadata*, read before any tool runs. Add `vyuha/agent/mcp_scanner.py` : normalise (L0) then apply the existing injection rules + a few MCP-specific ones (hidden-instruction, exfiltration, "when the agent asks X do Y" conditional-trigger, description/behaviour mismatch) to each MCP tool's `description` and `inputSchema` at registration time. Block or quarantine poisoned tools before they enter context.

Component B — Stateful action / capability policy (extend ToolPolicy)

Move `vyuha/agent/tool_policy.py` from single-step taint toward an **instruction hierarchy** (system > user > tool) and an **action-sequence** check: track the sequence of (read-untrusted → dangerous-action) across the turn, require confirm/block when an untrusted read is followed by an exfiltration/transfer/delete, and constrain the action space by default (least privilege). This is the free-compute, black-box approximation of ShieldAgent / CaMeL - stated honestly as weaker than their guarantees.

Component C — Session-level escalation detector (extend the L5 monitor)

Extend `vyuha/ops/monitor.py` to a per-conversation mode that scores the whole session graph (running max L1/L2 score, topic-drift, refusal-then-retry pattern) to catch Crescendo-style multi-turn escalation that any single message passes.

Evaluation (what makes it a result, not a claim)

Axis	Test set	Metric
Tool poisoning	Curated poisoned MCP tool descriptions (public MCP-attack corpora + hand-built)	detection rate; benign-tool pass-rate
Agent injection	AgentDojo (P11, scaled) with/without the new action policy	injection ASR; task utility
Multi-turn	Crescendo-style escalation set	session-level detection; per-message FPR

Deliverables & effort

- **Code:** `vyuha/agent/mcp_scanner.py` (new), extended `tool_policy.py` and `ops/monitor.py`, `eval/mcp_eval.py` (new), and a **P12 Kaggle notebook**.
- **Compute:** free - the scanners are rule/normalise-based (CPU); only the AgentDojo arm needs an LLM backend (free Groq, as in P11).
- **Effort:** Components A and C are small (days); Component B is the substantive piece; the eval is the time cost.

Honest positioning (carry into the paper). This keeps Vyuha black-box and free-compute; it does **not** match CaMeL's capability guarantees or ShieldAgent's verifiable policies. The defensible contribution is *composition + reproducibility + being MCP-native and stateful on free compute* - and saying, at every layer, exactly where stronger (white-box, formally-verified, or paid-compute) work exists.

6 · References & method note

Grading: **PRIMARY** peer-reviewed / official; **SECONDARY** reputable overview; **BLOG** vendor/SEO, orientation only.

- **PRIMARY** Benchmarking Open-Source Safety Guard Models — arXiv:2605.28830 (Apr 2026). <https://arxiv.org/abs/2605.28830>
- **PRIMARY** The Attacker Moves Second (adaptive attacks bypass 12 defenses) — OpenReview 7B9mTg7z25.
- **PRIMARY** Crescendo multi-turn jailbreak — USENIX Security 2025 / arXiv:2404.01833; “Multi-Turn Jailbreaks Are Simpler Than They Seem” arXiv:2508.07646.
- **PRIMARY** MCP-38 threat taxonomy arXiv:2603.18063; Trust No Tool arXiv:2605.17453; CASCADE (MCP cascaded defense) arXiv:2604.17125; NSA MCP Security guidance.
- **PRIMARY** Circuit Breakers (Representation Rerouting) — NeurIPS 2024 / arXiv: 2406.04313; contrastive representation learning arXiv:2506.11938.
- **PRIMARY** ShieldAgent (verifiable safety-policy reasoning) arXiv:2503.22738; Provably Secure Agent Guardrail arXiv:2605.29251.
- **SECONDARY** OWASP Top 10 for Agentic Applications 2026 (genai.owasp.org); GuardReasoner-Omni arXiv:2602.03328; X-Guard arXiv:2504.08848.
- **BLOG** Vendor/SEO overviews (getmaxim, futureagi, intelscroll, practical-devsecops) — used for orientation only; their specific statistics are not cited as fact.

Method. Standard-tier deep-research protocol: question framed to the decision it serves, prior stated and tested against disconfirming searches, sources graded before use, claims traced to primary origin, confidence stated per finding, and the ranking’s falsifiers named. As-of date: 5 August 2026.